

De 5-Minuten Repo Security Checklist

Een snelle handmatige controle vlak voor je pusht — van CipherCapital

1. Secrets

- Doorzoek je repo op veelvoorkomende secret-patronen: **grep -rEn "(api[_-]?key|secret|password|token)s*="** .
- Check ook je git-geschiedenis — een verwijderd secret in de commit-historie is nog steeds blootgesteld: **git log -p | grep -i "api_key"**
- Bevestig dat **.env** en alle credential-bestanden in **.gitignore** staan — en dat dit *altijd al* zo was, niet pas achteraf toegevoegd.

2. Dependencies

- Check op bekende kwetsbaarheden in je packages: **npm audit** of **pip-audit**, afhankelijk van je stack.
- Zoek naar dependencies die al meer dan een jaar niet zijn bijgewerkt — verlaten packages zijn een veelvoorkomend toegangspunt.
- Pin versienummers in productie — vermijd open-eindige ranges zoals **^** of ***** voor alles wat security-gevoelig is.

3. Infrastructure as Code

- Dockerfiles: bevestig dat je niet als **root** draait — voeg een **USER**-instructie toe.
- Zoek naar hardcoded IP's, poorten of credentials in Terraform-/Kubernetes-manifests.
- Bevestig dat cloud storage buckets (S3, GCS) standaard privé staan, niet public-read.

4. Snelle winst

- Zet 2FA aan op GitHub, GitLab en elk CI/CD-platform dat je gebruikt — bij voorkeur met een hardware-key, niet SMS.
- Zet Dependabot (of vergelijkbaar) aan zodat dependency-meldingen je automatisch bereiken, niet pas bij een review.
- Voeg een **SECURITY.md**-bestand toe aan je repo, zodat bijdragers weten hoe ze verantwoord een probleem kunnen melden.

Wil je dit automatisch laten draaien bij elke commit, over je hele repo, in plaats van handmatig te controleren? Dat is precies wat SecurityAuditAI automatiseert — volledige scan in minder dan 2 minuten, gratis te proberen. [ciphercapital-hubpagina](#) → **Gratis security-audit**.

CipherCapital — cybersecurity-tutorials die daadwerkelijk fixes opleveren, geen theorie.